



Secure Image Storage

C Secure Image Storage

keymoon, Yu_212, d47, kam1tsur3, Xvezda 외 6명이 해결했습니다.

web

Description

It is a very secure image storage

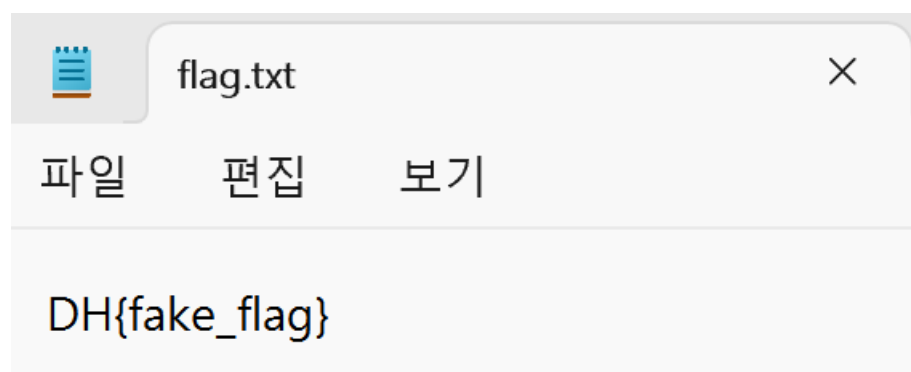
app

flag

requirements

schema

문제 파일을 다운 받으니 다음과 같은 파일이 나왔다.



flag.txt 파일을 여니 가짜 FLAG 값이 나왔다.

더 이상 단서가 없을 듯 하여 app.py , schema.sql 파일을 살펴봤다.

```
import sqlite3
from time import sleep
from hashlib import md5
from urllib import parse
from uuid import uuid4, UUID
from datetime import datetime
from selenium import webdriver
from os import urandom, getcwd, path, makedirs
from selenium.webdriver.chrome.service import Service
from flask import Flask, request, g, render_template, redirect, send_file, make_response

app = Flask(__name__)
app.secret_key = urandom(32)

try:
    FLAG = open('./flag.txt', 'r').read()
except:
    FLAG = 'DH{fake_flag}'

DATABASE = 'database.db'

def get_db():
    db = getattr(g, '_database', None)
    if db is None:
        db = g._database = sqlite3.connect(DATABASE)
        db.row_factory = sqlite3.Row
    return db

@app.teardown_appcontext
def close_connection(exception):
    db = getattr(g, '_database', None)
    if db is not None:
```

```

        db.close()

def init_db():
    with app.app_context():
        db = get_db()
        with app.open_resource('schema.sql', mode='r') as f:
            db.cursor().executescript(f.read())
        db.commit()

def get_data(query, args=(), one=False):
    cur = get_db().execute(query, args)
    rv = cur.fetchall()
    cur.close()
    return (rv[0] if rv else None) if one else rv

def insert_data(query, args=()):
    db = get_db()
    cur = db.cursor()
    cur.execute(query, args)
    db.commit()
    rowcount = cur.rowcount
    cur.close()
    return rowcount

def access_file(path, cookie={"name": "name", "value": "value"}):
    try:
        service = Service(executable_path="/chromedriver-linux64/chromedriver")
        options = webdriver.ChromeOptions()
        for _ in [
            "headless",
            "window-size=1920x1080",
            "disable-gpu",
            "no-sandbox",
            "disable-dev-shm-usage",
        ]:
            options.add_argument(_)
        driver = webdriver.Chrome(service=service, options=options)
        driver.implicitly_wait(3)
        driver.set_page_load_timeout(3)
        driver.get(f"http://127.0.0.1:8000/")
        driver.add_cookie(cookie)
        driver.get(f"http://127.0.0.1:8000/{path}")
        sleep(1)
    except Exception as e:
        print(e, flush=True)
        driver.quit()
        return False
    driver.quit()
    return True

@app.route('/', methods=['GET'])
def index():
    return redirect('/upload')

@app.route('/upload', methods=['GET', 'POST'])
def upload():
    if request.method == 'GET':
        return render_template('upload.html')
    else:
        username = request.form['name'].strip()
        if len(username) > 30 :
            return render_template('upload.html', msg= 'The length of the username must be 30 characters or less')
        file = request.files['file']
        if file.filename == '':
            return redirect('/upload')

        if len(path.splitext(file.filename)[0]) > 30:
            return render_template('upload.html', msg= 'The length of the filename must be 30 characters or less')

        if ('.' in path.splitext(file.filename)[0]) or ('/' in path.splitext(file.filename)[0]):
            return render_template('upload.html', msg= 'Not allowed character')

```

```

if path.splitext(file.filename)[1].lower() != '.png':
    return render_template('upload.html', msg= 'Only PNG files are allowed')

if file.content_type != 'image/png':
    return render_template('upload.html', msg= 'Only PNG files are allowed')

username = parse.quote(username, safe='')
filename = username + '_' + parse.quote(path.splitext(file.filename)[0], safe='')
uuid = str(uuid4())
base_path = getcwd()
full_path = path.join(base_path+'/static/', uuid)
makedirs(full_path)
try:
    file.save(full_path + '/' + filename)
except Exception as e:
    print(e, flush=True)
    return render_template('upload.html', msg= 'Something error')

date = datetime.now().isoformat()
encoded_data = (username+filename).encode('utf-8')
md = md5()
md.update(encoded_data)
hash = md.hexdigest()
insert_data('INSERT INTO files (username, filename, hash, uuid, date) values(?,?,?,?,?)', [username,filename,hash,uuid,date])
return render_template('upload.html', msg='Upload success')

@app.route('/<username>', methods=['GET','POST'])
def storage(username):
    files=get_data('SELECT * FROM files WHERE filename LIKE ?', [username+'_%'])
    return render_template('storage.html', files=files)

@app.route('/static/<uuid>/<filename>')
def show(uuid, filename):
    uuid_obj = UUID(uuid, version=4)
    if str(uuid_obj) != uuid:
        return 'Not vaild UUID'
    file = get_data('SELECT * FROM files WHERE uuid=?', [uuid], one=True)
    if not file:
        return 'Directory does not exist'
    base_path = getcwd()
    if path.exists(base_path+f'/static/{uuid}/{filename}'):
        res = make_response(send_file(base_path+f'/static/{uuid}/{filename}'))
        # res.headers.add('X-Content-Type-Options', 'nosniff')
        res.headers.add('Content-Type', 'image/png')
        res.headers.add(f'X-Confirmed-{parse.unquote(filename)}', parse.unquote(file[1]) + '_' + file[3])
        for header in res.headers.to_wsgi_list():
            if 'Content-Type' in header[0]:
                if (not header[1].startswith('image/png')) and (not header[1].startswith('application/octet-stream')):
                    return 'Invaild Content-Type'
        return res
    else:
        return 'File does not exist'

@app.route("/report", methods=["GET", "POST"])
def report():
    if request.method == "POST":
        path = request.form.get("path")
        if not path:
            return render_template("report.html", msg="fail")
        else:
            if access_file(path, cookie={"name": "flag", "value": FLAG}):
                return render_template("report.html", msg="Success")
            else:
                return render_template("report.html", msg="fail")
    else:
        return render_template("report.html")

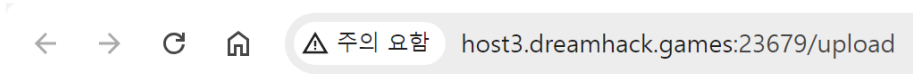
if __name__ == "__main__":

```

```
init_db()
app.run(host='0.0.0.0', port=8000)
```

```
DROP TABLE IF EXISTS file;

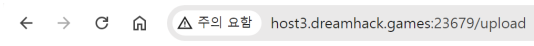
CREATE TABLE files (
  id INTEGER PRIMARY KEY AUTOINCREMENT,
  username TEXT NOT NULL,
  filename TEXT NOT NULL,
  hash TEXT NOT NULL,
  uuid TEXT NOT NULL,
  date TEXT NOT NULL
);
```



Upload a file

Username:

test.png



Upload a file

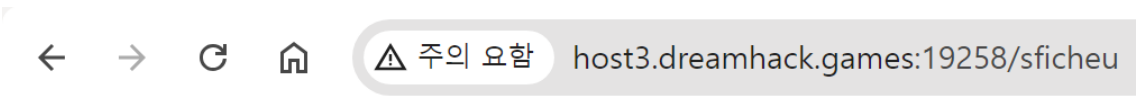
Upload success

Username:

선택된 파일 없음

우선 코드 제대로 실행되는지 확인하기 위해 `test.png` 파일을 업로드 해봤다.

`test.png` 파일을 선택한 후 Upload 버튼을 누르자 Upload success라는 문구가 나오는 것을 볼 수 있다.



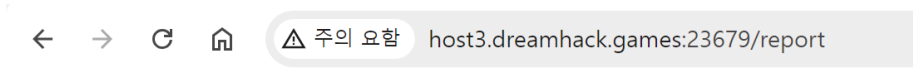
Stored Files

- [sficheu test](#)

`<username>` 페이지로 이동하기 위해 업로드할 때 사용했던 Username을 입력하니, 앞서 업로드 페이지에서 업로드했던 사진 목록이 뜨는 것을 볼 수 있다.

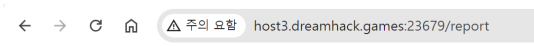


해당 사진 목록의 사진을 누르니, `/static/<uuid>/<filename>` 경로로 들어오며 `test.png` 이미지가 제대로 뜨는 것을 볼 수 있다.



Report to Admin

Path:



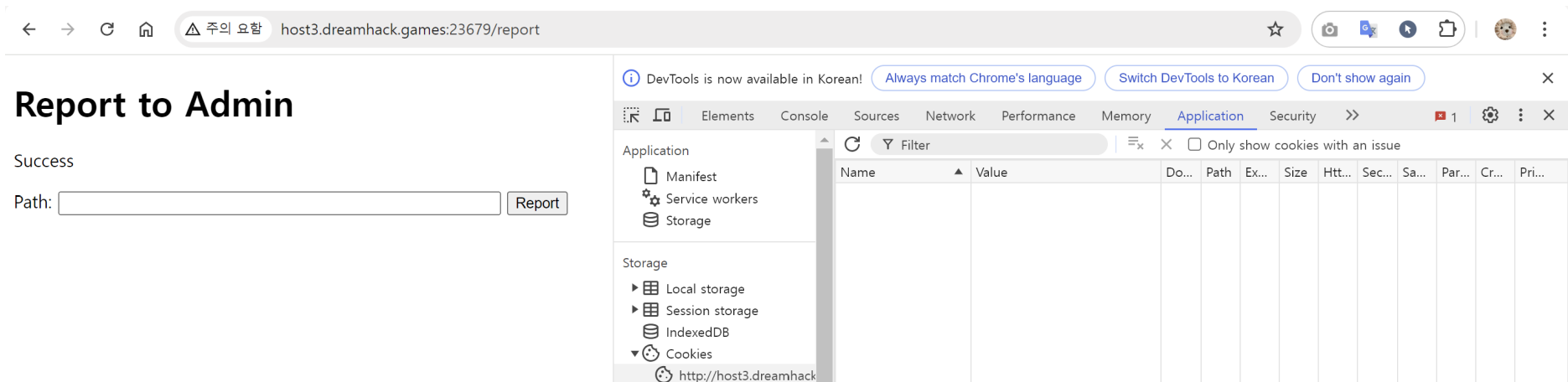
Report to Admin

Success

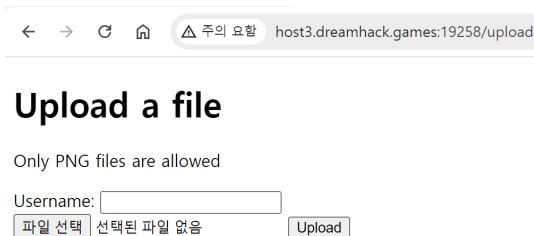
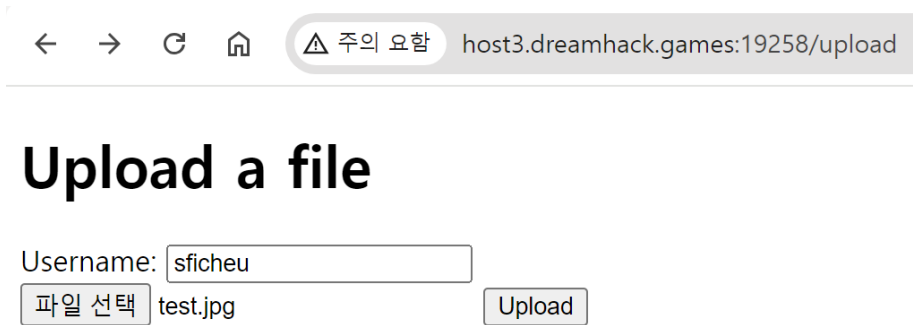
Path:

`/report` 페이지로 이동하여 앞서 업로드했던 이미지의 경로를 입력했더니 Success 문구가 화면에 나왔다.

해당 페이지의 코드를 살펴보니 FLAG를 나타내는 쿠키 값을 통해 접근이 가능하면 Success 문구를 띄우는 것 같아 보았다.

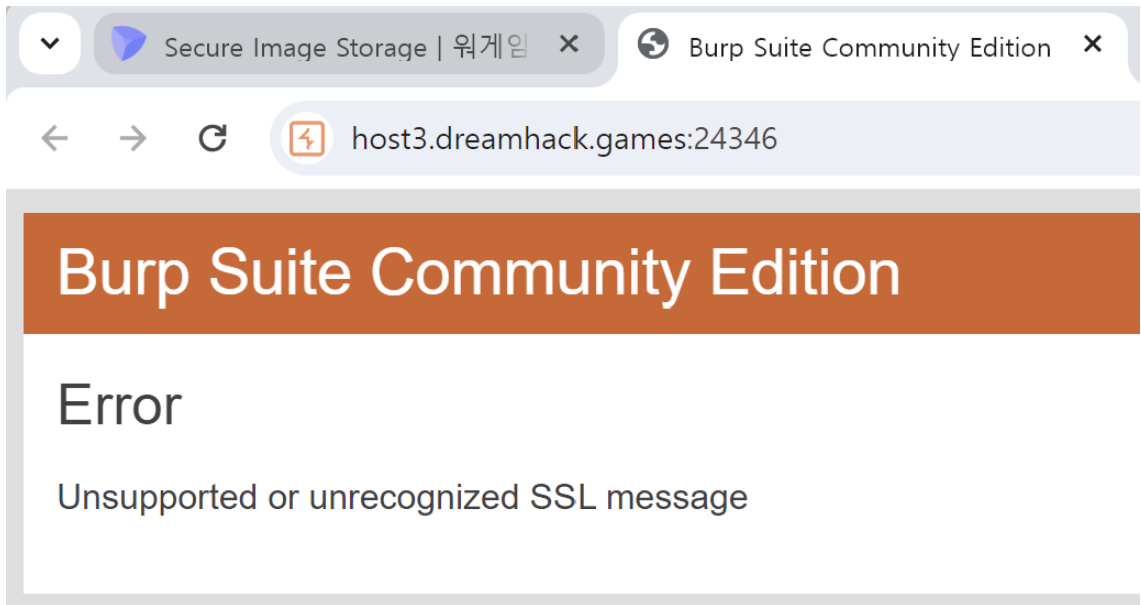


이러면 쿠키 값에 FLAG에 관련된 정보가 있을까 해서 찾아봤지만 비어있는 것을 볼 수 있다..



혹시 몰라 PNG 이미지 대신 JPG 이미지를 업로드하니 `Only PNG files are allowed` 문구와 함께 거절당했다.

이를 burp suite에서 PNG 파일로 조작해보려는데..



실패했다..

이미지 업로드를 php 쉘로 받아 burp suite로 조작했던 과거의 위게임 방법을 사용하면 되는건가 싶어 해당 방법 또한 시도해보려고 했는데 burp suite가 제대로 실행 되면 시도해봐야겠다..